

**THE WORLD NEEDS
A FREE GLOBAL
VULNERABILITY
INTELLIGENCE
PLATFORM.**

**WANT TO
HELP?**

Introduction

WHOAMI

Olle E. Johansson



- OWASP member, project leader, ECMA TC54 invited expert
- Open Source developer (Asterisk, Kamailio, DNS TAPIR)
- Active in Eclipse ORCWG
- Active in OpenSSF
- Active in IETF
- Founder SBOM Europe
- Consultant, trainer, troublemaker
- I have my garden in Sollentuna, Sweden



Vulnerability intelligence platforms are shaking

The NVD program is gone. More or less.

What is the EUVD?

Legislators adding pressure.

The CVE program is still around. But for how long?

Commercial vendors filling the void.

My SBOM check shows no issues!

What should we do?

My personal view

Towards a global federated vulnerability platform



Unfortunately, many things at the same time.

Help the CVE program and the CNAs in their work and start a dialogue about contributing.

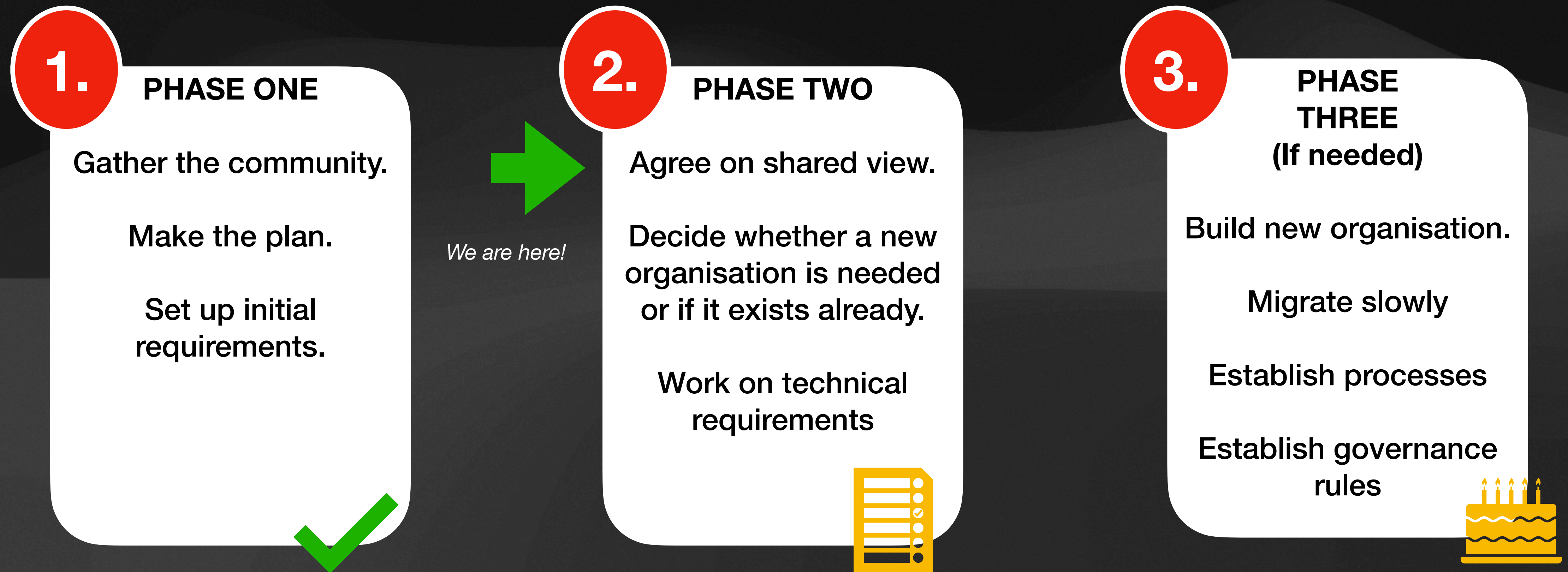
Short term

Work on a global solution and a migration path

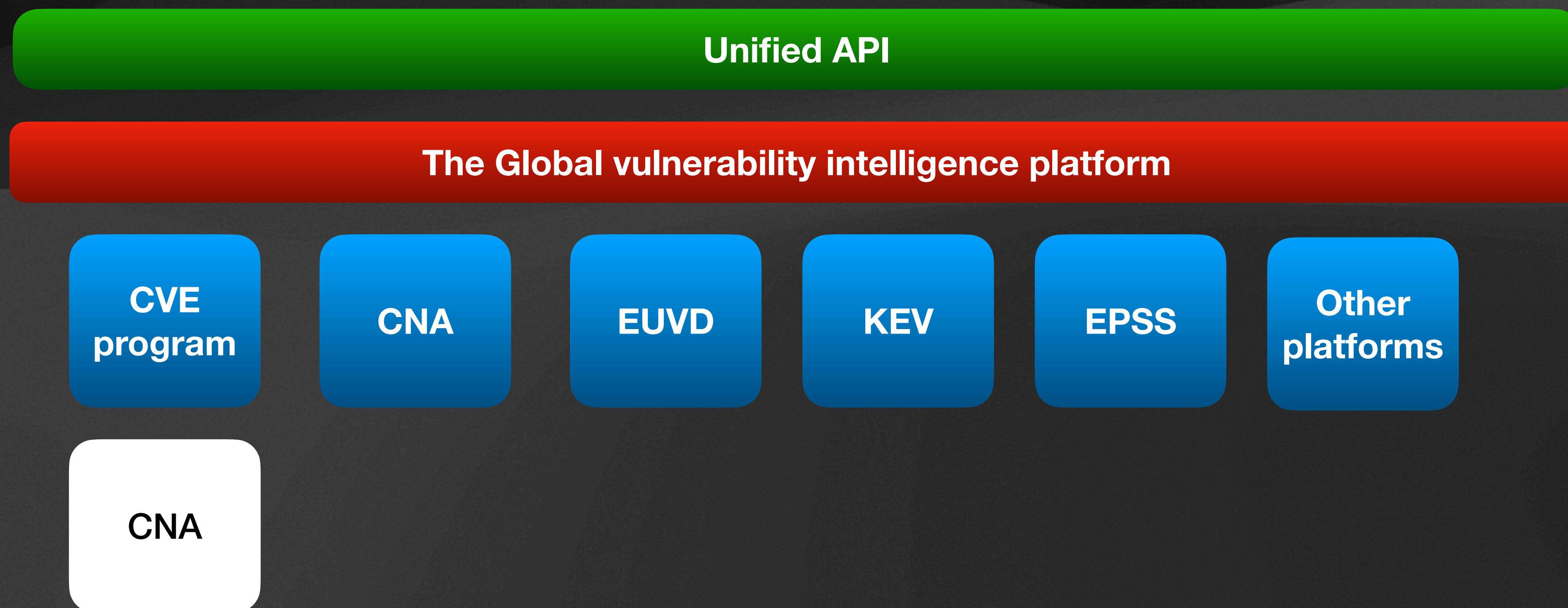
Long term

The logo for the GVIP Project. It features a red square with a white diagonal line on the left. To its right, the text "GVIP" is in large, bold, black letters, with the "V" in red. Below "GVIP", the word "PROJECT" is in smaller, bold, black letters.

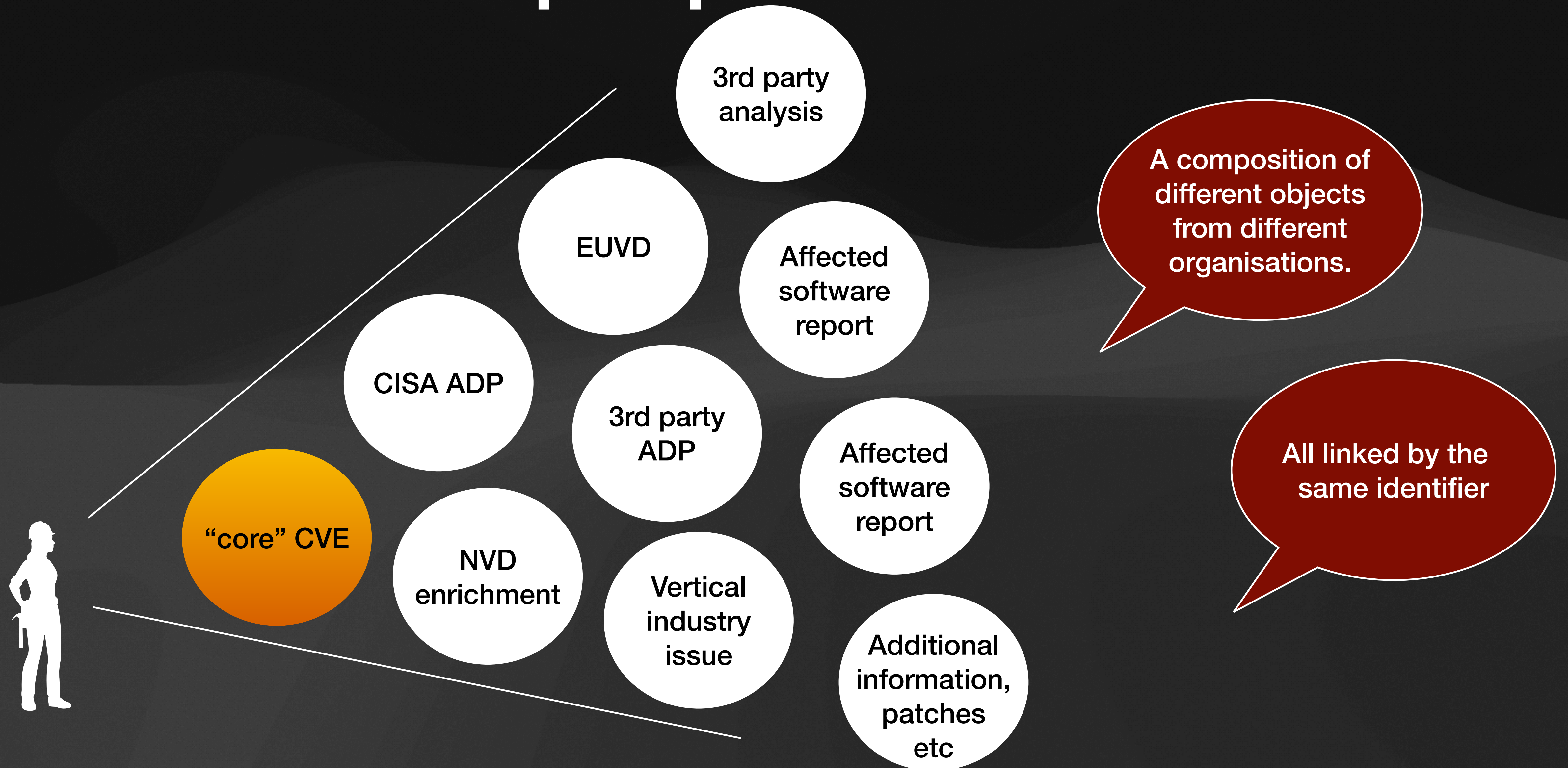
The GVIP project plan



A view of a potential solution



From the user perspective



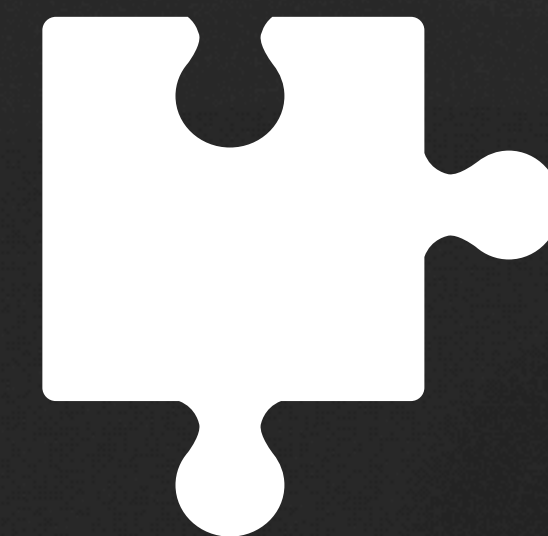
Requirements for a new system



GVIP requirements

#1: FEDERATION

- **FEDERATION**: A global system needs to be operated by many actors, following the same rules and formats for managing vulnerability data. By using the same namespace, collisions in identifiers (CVE) will be avoided. The federation needs decentralisation.



GVIP requirements

#2: GLOBAL

- **GLOBAL**: We need a multistake-holder organisation with global participation to manage the standards, the code of conduct, but maybe not the systems



GVIP requirements

#3: FREE

- **FREE:** The data shall be freely accessible and replicable worldwide.
No single jurisdiction owns this data. Everyone needs availability.

GVIP requirements

#4: INTEROPERABILITY

- **INTEROPERABILITY**: The API for lookups needs to be standardised, as well as the data format and standards for replication of data.



GVIP requirements

#5: NAMING

- **NAMING:** Vendors and creators (open source projects) need to be in control of their identifiers (DNS name) and the product names, no one else. The system may have a small managed namespace for software creators without a DNS name registration, which of course can't guarantee any similarity with a natural name in order to avoid collisions.

PURL

GVIP requirements

#6: GLOBAL NAMESPACE

- **GLOBAL NAMESPACE:** The identifier for a vulnerability needs to be globally unique

GVIP requirements

#7: TRUST

- **TRUSTED and AUTHORITATIVE:** There needs to be a high level of trust in the system and the provided data, by using digital signatures and transparency systems to monitor the systems for invalid changes in data. This system should be authoritative for legislations and vertical standards world wide. All vulnerabilities must be independently verifiable.

GVIP requirements

#8: REPLICATION

- **REPLICATION FRIENDLY:** The data needs to be replication friendly. One reason is that APIs can be used to track the content of SBOMs for a specific IP/Enterprise and having data locally (and off line) is much faster. In addition, local data offloads the traffic from the API endpoint.
- There should be no cost or other requirements put on availability for replication

GVIP requirements

#9: EXTENSABILITY

- **EXTENSABILITY** with preserved integrity
- Data provided should not change, integrity should be protected
- Many providers should be able to provide additional data (like NVD, KEV and EUVD)
- Security researchers should be able to provide additional data (or corrections) like governmental organisations
- Users make a decision about whom to trust

Summary of requirements

The global vulnerability intelligence platform



FEDERATION

Many sources, one shared view.

GLOBAL

Stakeholders and funding from across the globe.

FREE

Vulnerabilities are a public good

INTEROPERABILITY

A shared set of open standards and open data formats

NAMING

The creator names his creation

GLOBAL IDENTIFIER

A globally unique shared namespace

TRUST

Users needs to be able to validate data correctness and origin

REPLICATION

Users need local access to the data

EXTENSABILITY

Attackers and risk continuously change.

Coming steps

Gather around the round table

The first part, we have started



- 1. **Talk with everyone**, get organisations and individuals engaged
- 2. **Open Forums**: Set up a number of meetings to gather requirements and collect input on the process in order to be able move forward towards a more resilient solution to support global efforts related to cyber security. This process needs to have a **diverse set of parties** involved in order to build trust and confidence in a gradual buildup of a new platform.
- 3. The goal with the first part of this process is to agree on **governance** and **base requirements** similar to the requirements above, to agree on organisational rules (bylaws) and set up an interim board/work group to manage the process of forming the organisation (if needed)

2.

Part two: Gears in motion

Setting up an organisation

- 1. Organise a **series of workshops** to gather ideas and input from a worldwide community, creating a set of documents as input for further work in an organised way.
- 2. **Agree on requirements** on various parts of the technology solution
- 3. **Agree on a standards process** (using existing standard organisations wherever possible)
- 4. Start defining API's, formats, naming



Part three: Slow migration

Building trust and migrating



OPTIONAL

- Building trust takes time
- The CVE program needs to be part of this process and be part of the solution
- CNAs may either decide to work as before (with the CVE program) or contribute directly as part of the federation
- Other existing vulnerability databases, vendors and actors are of course invited to join the efforts

Summary of the proposed process

- 1: Reach an agreement on a working group - “interim board”
- that works on the next step of building an organisation
- 2: Organise a large amount of open workshops to gather input from stakeholders, try to form some level of baseline agreement on the way forward both on organisational and on technical requirements
- 3: Create the new organisation (if needed) and start development of needed standards to build the solution
- 4. Live happily ever after :-)

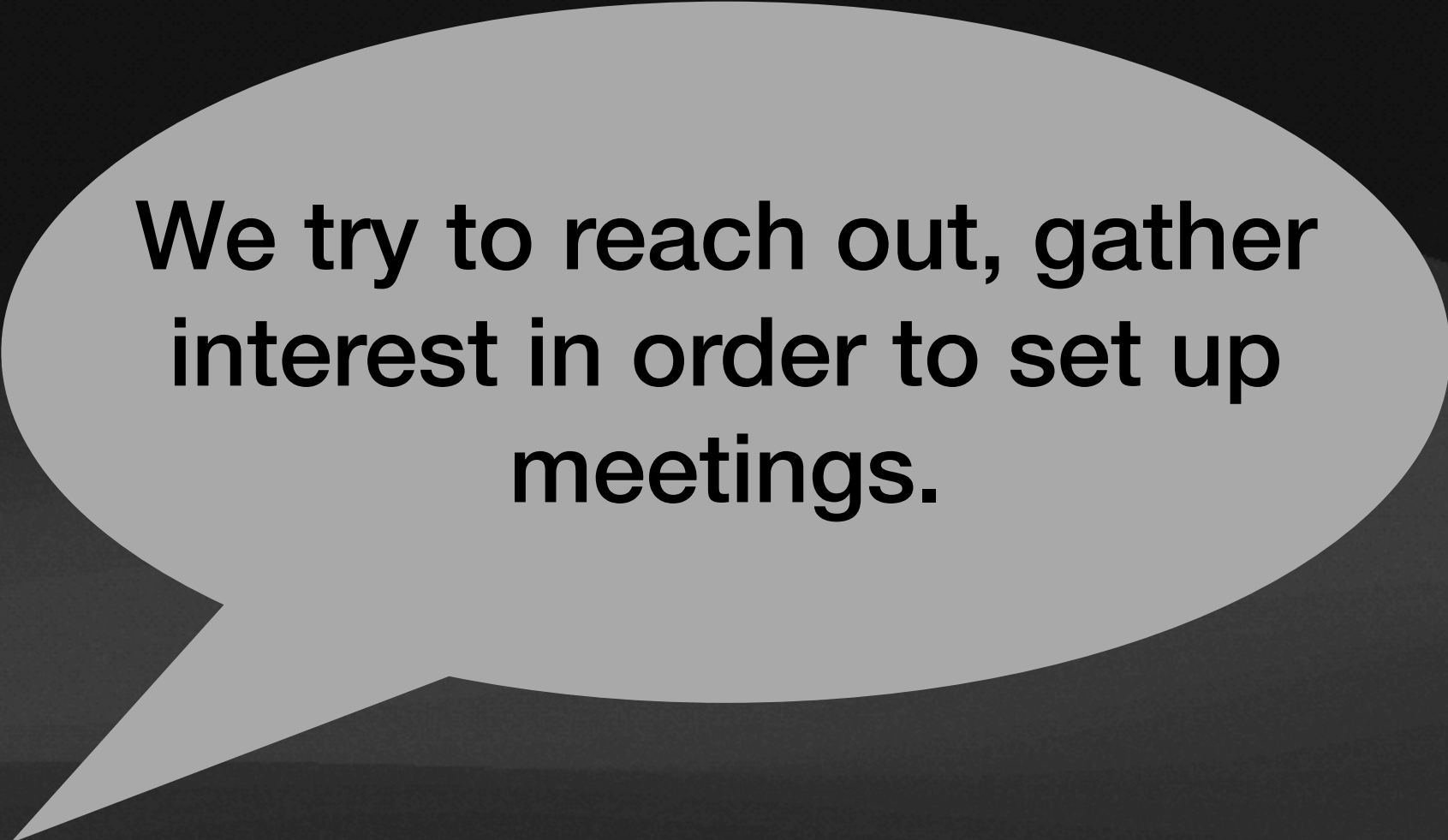


Interested parties so far

Participating in the discussions

- OWASP Foundation
- OpenSSF
- Eclipse Foundation
- Erlang Ecosystem Foundation
- Apache Foundation
- Open Forum Europe
- The Sovereign Tech Resilience program
- aboutcode.org
- A large group of cybersecurity experts

- (These are the ones we have talked with. I guess there are many more)



We try to reach out, gather interest in order to set up meetings.



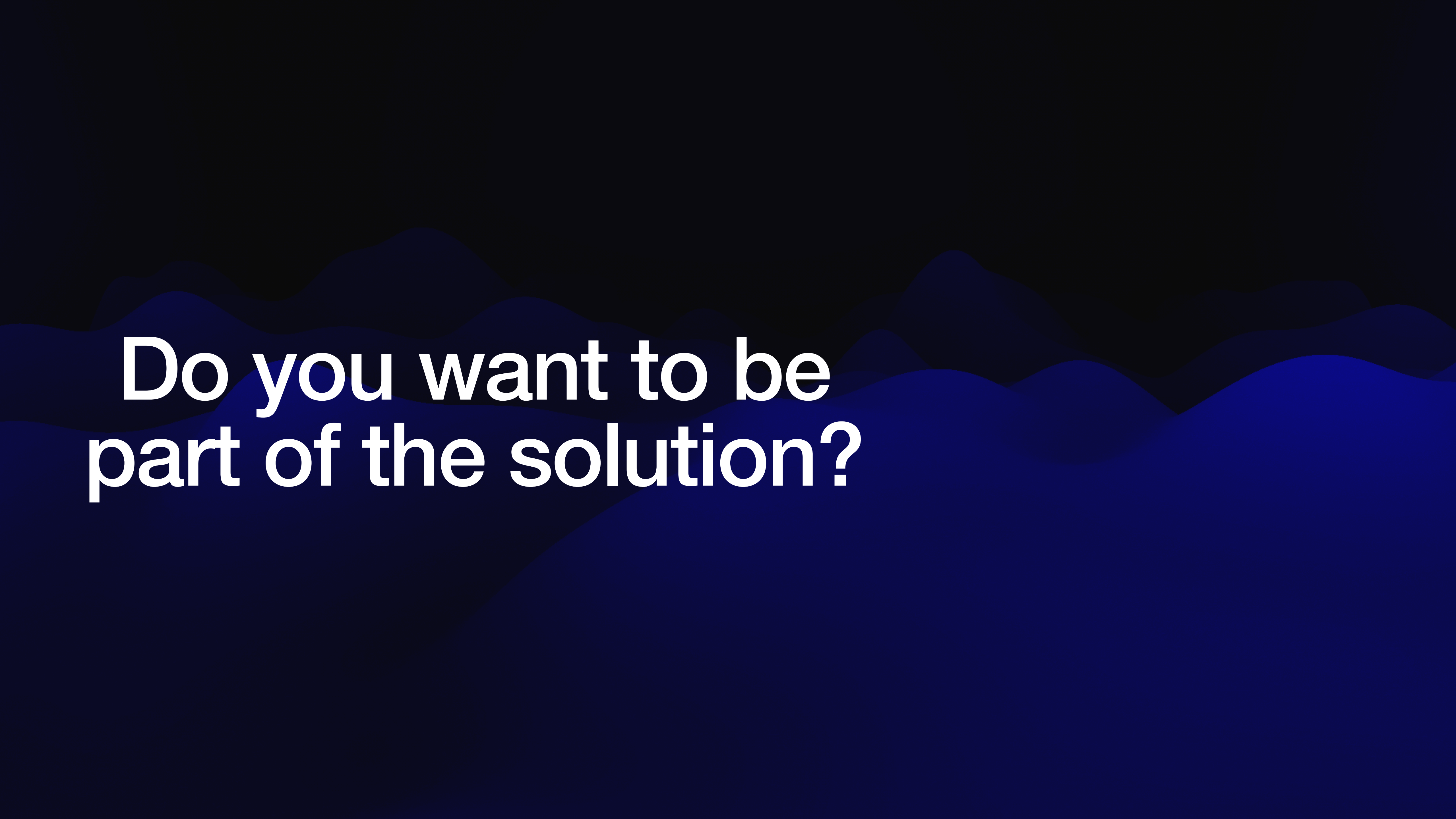
This will take time.



Patience, my friends, is a virtue



I think we can do this.

The background features a series of overlapping, wavy shapes in dark blue and black, creating a layered, mountain-like or ocean-like effect. The text is centered over these shapes.

Do you want to be
part of the solution?

Points of contact



WWW.GVIP-PROJECT.ORG

- Web site: <https://www.gvip-project.org>
- LinkedIn, Mastodon
- Mailing list: cve@owasp.org
- OpenSSF Vulnerability disclosures working group
<https://github.com/ossf/wg-vulnerability-disclosures>
- Documents: github.com/gvip-project
- Blogs, videos
- My email: oej@edvina.net

Q/A

oej@edvina.net

 **GVIP**
PROJECT